

Review: pre-execution screening and runtime boundaries (r4.6)

- **Status:** REVIEW AND ADJUDICATION. Decisions PD-93 to PD-98 are adjudicated by Claude at the owner's request, subject to the owner, on the same terms as ADJUDICATION-R4.5.md. One defect was reproduced and fixed with a test (HF-36). One weakness was shown by a deterministic simulation and is scheduled for a fix (F-1).
- **Revision:** r4.6, 2026-09-30, by Claude.
- **Asked:** the owner asked to review and adjudicate a set of hardening recommendations. They say which screening subroutines help, where they fall short, and which runtime and kernel boundaries are required:
 - screening: instruction disassembly (Capstone or yaxpeax), ELF parsing (Goblin), adversarial-anchor containment, secrets exclusion;
 - boundaries: Landlock and privilege dropping; a supervisor/worker split; WASI Preview 2 with fuel; `O_NOFOLLOW`, device and inode pinning, and 0700/0600 modes.

1. Verdict in brief

The recommendations' central claim is right, and this pattern was built on it. Screening before execution cannot stop a process that is taken over while it runs; only kernel and runtime boundaries contain that. Most of the required boundaries are already built and tested here.

Checking the claims against the code found one real gap. The Landlock domain granted **execute** wherever it granted read, including the output directory. A binary written by a compromised daemon, or dropped by someone else into a folder the daemon watches, could be run. That is fixed (HF-36).

Two screening proposals are rejected or reshaped. They would not do what they promise for this pattern, and a better control exists:

- **Disassembly gate (PD-93):** rejected as a gate. Execute-denial and digest pinning replace it.
- **ELF parsing (PD-94):** reshaped into an activation-time check in the battery.

Recommendation	Verdict	Status here
Disassembly gate for <code>svc/syscall</code> (PD-93)	REJECTED as a gate; the goal is met by execute-denial (HF-36, built) and digest-pinned executables (planned)	Execute-denial built in r4.6
ELF extraction without <code>ld.so</code> (PD-94)	ADOPTED WITH MODIFICATION: an activation-time battery check of the allowlisted executables, not a runtime parser	Planned (DB check)
Adversarial anchor containment (PD-95)	ADOPTED; already built for the digest. For models, delimiters are a mitigation, not a boundary	Built (<code>render.py</code> , DB-10); PD-61
Data and secrets exclusion (PD-96)	ADOPTED WITH MODIFICATION: credential stores join the always-denied paths; secret-shaped names are refused; the limits are stated	Partly built (<code>~/ .ssh</code> , <code>~/ .gnupg</code>); rest in contract 4.0.0
Landlock and privilege dropping	ADOPTED, already built; the network claim is corrected (§3)	Built; execute gap fixed (HF-36)
Supervisor/worker split	ADOPTED (PD-72), with one added requirement: the supervisor holds the ledger (PD-97)	Designed
WASI Preview 2 with fuel	DEFERRED (PD-73, PD-74), with the trigger restated and the claim corrected	Designed
<code>O_NOFOLLOW</code> , device and inode pinning, 0700/0600 (PD-98)	ADOPTED WITH MODIFICATION: modes already built; the read race (F-1) closed by checking <i>after</i> opening	Modes built; F-1 fix planned

Recommendation	Verdict	Status here
"Non-security utilities offer no defence"	AGREED , with a rule: a control counts in the safety case only with a test that shows it blocking something (U-7)	These utilities are not in this repository

2. HF-36: nothing the daemon writes, or merely reads, may be executed

Found by checking the recommendation "restricts writes strictly to a governed scratch directory, making it impossible to drop executables into system paths" against `landlock.py`. The claim holds for system paths; `ProtectSystem=strict` and `Landlock` both refuse writes there. But the rights constant used for reads included `ACCESS_FS_EXECUTE`, and the output directory received every right the ABI handles. So:

- execute was granted on the daemon's own output directory, which it can write;
- execute was granted on every declared read path, such as an inbox other people drop files into.

Reproduction (`evidence/r4.6/exec_before.txt`): in a forked child under the real, enforced domain (`Landlock ABI 7`), with the same binary also run outside the domain as a control:

execve of	Before (r4.5)	After (r4.6)
<code>/usr/bin/true</code> (the system path, where allowlisted commands live)	ran	ran
A copy written into the output directory	ran	refused, <code>EACCES</code>
A copy dropped into a declared read directory	ran	refused, <code>EACCES</code>

Why it mattered, and its limits. Reaching `execve` from daemon code already requires getting past the purity check and the audit hook, which forbid process creation outside `ctx.run`. A native bug would also work, for example in Git parsing a hostile repository. `Landlock` is the layer meant to hold when those fail, and `DB-17` exists to prove it holds on its own. It held for reads, writes and TCP, but not for execution.

Severity is **Medium**: the attacker needs code execution first. The gap then gave them a way to run dropped tooling, and to run anything placed in a watched folder.

Fix (`landlock.py`):

- **Execute only on the system paths.** Execute stays only on `system_read_paths()`, which are the interpreter and system library paths and the only place allowlisted commands resolve (`/usr/bin`, `/bin`).
- **Read without execute elsewhere.** The daemon's folder and every declared read get read without execute.
- **Everything but execute on the output directory.** It keeps every other right.

No contract change was needed: the contract never promised execute there, and no daemon can legitimately run anything outside the allowlist.

Test:

`tests/test_landlock.py::EnforcementTests::test_nothing_the_daemon_can_write_or_merely_reads_can_be_executed` fails on r4.5 and passes now. The full suite passes (211), and the four reference daemons pass all 19 checks.

3. The recommendations, one by one

3.1 Instruction disassembly as a gate (PD-93): REJECTED as a gate

- **It cannot separate good from bad binaries.** Every ordinary program makes system calls, through its C library if not directly. A gate that refuses `svc` or `syscall` instructions either refuses every binary (Git included) or checks only direct instructions, which a payload avoids by calling `libc`.

- **It does not see what matters most.** A payload does not need new machine code:
 - a script for an interpreter already on the host;
 - code built in memory at run time;
 - a return-oriented chain inside an allowed binary.

The recommendation's own "falls short" section says as much.

- **It adds attack surface to the trusted side.** Parsing attacker-supplied binaries with a large native disassembler inside the trusted component is itself a risk. It would have to be sandboxed like any other parser of hostile input.
- **This pattern does not load unknown binaries.** A daemon may run only commands named in its manifest:
 - resolved from `/usr/bin:/bin`;
 - never shells, interpreters, network clients or command runners (`FORBIDDEN_COMMANDS`);
 - executed by the skeleton's bounded runner, with an allowlisted environment, so no `LD_PRELOAD`.

The package manager owns those files, and `ProtectSystem=strict` makes them read-only to the daemon.

What replaces it:

1. **Execute-denial everywhere else** (HF-36, built).
2. **Digest pinning (planned).** `DAEMON_START` records the SHA-256 of each resolved allowlisted executable next to its version. The activation register (PD-40, PD-84) compares it with the digest approved at activation, and a mismatch is a refusal. This checks provenance directly, instead of guessing intent from instructions. It is an additive change.
3. **Disassembly may still help with forensics** or untrusted *plugins* (§3.7), run in a sandbox, as evidence, never as the gate.

3.2 ELF extraction without `ld.so` (PD-94): ADOPTED WITH MODIFICATION

The useful part is narrow. Loader hijacking comes from three places:

- **The environment.** Closed here: children get an allowlisted environment (`proc.SAFE_ENV`).
- **Writable library directories.** Closed by `ProtectSystem=strict` and by Landlock denying writes outside the output directory.
- **RPATH/RUNPATH entries that point at writable places.** Not checked today.

Adopted as a battery check at activation, not a runtime parser. For each allowlisted executable the check requires:

- the file is owned by root and not writable by the daemon's user;
- it lies under a system path;
- its dynamic section has no RPATH or RUNPATH outside system library directories;
- its digest is recorded (§3.1).

The ELF dynamic section can be read with the standard library's `struct` module in well under a hundred lines, so no Rust or C parser joins the trusted side (PD-59 keeps the framework on the Python standard library). Planned as a new battery check.

3.3 Adversarial anchor containment (PD-95): ADOPTED, largely built

- **Built for the digest.** Untrusted text reaches the digest only as values placed by containment, never as structure (`render.py`, the WBS 3.0 ES5 rule). DB-10 probes it with hostile values for every daemon that has a digest. Event types are declared names, never observed text, and unsettled reasons are upper-case categories, never observed text (`ctx.unsettled`).

- **One correction, for models.** "Strict delimiters ensure untrusted data remains passive evidence" is too strong where a language model reads the data. Delimiters reduce prompt injection; they do not prevent it. The guarantee has to come from authority: whatever a model concludes from untrusted text is a proposal, never an action (S-6, CaMeL). PD-61 is adopted with that wording.

3.4 Data and secrets exclusion (PD-96): ADOPTED WITH MODIFICATION

Today:

- `~/.ssh`, `~/.gnupg`, `~/.claude`, `~/.codex`, `~/spark-core/data` and `~/spark-governance/history` are always denied, and can never be removed by a manifest.
- Landlock denies reading anything outside the declared reads, including in child processes, which inherit the domain.
- There is no rule for credential stores elsewhere, or for secret-shaped files *inside* a declared read.

Adopted, for contract 4.0.0, because both changes can make an existing manifest or daemon fail:

1. **More always-denied paths:** `~/.aws`, `~/.azure`, `~/.config/gcloud`, `~/.kube`, `~/.docker`, `~/.netrc`, `~/.git-credentials`, `~/.config/gh`, `~/.password-store`, `~/.pki`, `~/.local/share/keyrings`. The validator refuses a manifest whose reads include any of them.
2. **Secret-shaped names are refused by ctx before any byte is read:** `.env`, `.env.*`, `*.pem`, `*.key`, `*.p12`, `*.pfx`, `id_rsa*`, `id_ecdsa*`, `id_ed25519*`, `*.kdbx`. The attempt is recorded as a policy violation (fail closed), as any forbidden read is.

Limits, stated so nobody over-relies on it:

- Name patterns are a heuristic. A secret in `config.yaml` passes them.
- They do not apply to what a *subprocess* reads. Git reads a repository's files itself, so only path-level rules, which Landlock enforces on the child, reach there.
- The primary control stays the allowlist of declared reads.
- The "confused deputy" risk is small for observers, which accept no requests. It grows with the first request channel (class 2b and above), where the gate's rules apply.

3.5 Landlock and privilege dropping: ADOPTED, already built; one claim corrected

Built:

- the dedicated `User=`;
- `NoNewPrivileges=yes`;
- an empty `CapabilityBoundingSet=`;
- a Landlock domain applied once, irreversibly, before the daemon's code is imported;
- `ProtectSystem=strict`, `ProtectHome=read-only` and `PrivateTmp=yes`;
- `MemoryDenyWriteExecute=yes`;
- a seccomp filter (`SystemCallFilter=@system-service minus @privileged @resources`).

Correction. "Landlock ABI blocks `socket()`, `connect()`, and `bind()` calls entirely" is inaccurate:

- **Landlock network rules** (ABI 4 and later) restrict TCP `bind` and `connect`, by port. They do not stop `socket()` itself, UDP, or other address families.
- **Under systemd, this pattern closes the network with the unit:** `PrivateNetwork=yes`, `IPAddressDeny=any` and `RestrictAddressFamilies=AF_UNIX`.
- **Outside systemd**, as in the battery and tests, Landlock's TCP denial is the second layer. DB-17 shows it blocking `connect` with `EACCES`.

Each layer does part of the job, and the claim should name the layer that does each part.

3.6 Supervisor/worker isolation (PD-97): ADOPTED (PD-72), with one requirement added

"A corrupted worker cannot corrupt the append-only ledger" holds only if the worker has **no write access to the ledger at all**. The requirement:

- the supervisor alone opens and writes the ledger;
- the worker's Landlock domain grants it read on its inputs and write on a private scratch directory only (the shape `test_nested_child_domain_can_only_narrow_never_widen` already exercises);
- the worker returns its snapshot to the supervisor over a pipe, as bounded, typed data.

This also answers the recommendation's "falls short" section. Memory corruption in the parser (git, or a future format parser) is contained by the process boundary, not detected in advance.

3.7 WASI Preview 2 with fuel: DEFERRED (PD-73, PD-74); claim corrected

- **Today's code does not need it.** A daemon's own code is Python under the purity check, the audit hook and Landlock. There are no plugins.
- **The trigger for building it:** the first untrusted plugin, or a pure `decide()` moved to WASM as PD-59 proposes.
- **Fuel limits only CPU.** It bounds the instructions a call may use. Memory needs a separate limit (a resource limiter), and wall-clock time needs epoch interruption.
- **"Fork bombs" does not apply.** WebAssembly has no fork. The equivalent risk, runaway memory or time, needs the other two limits.

3.8 Filesystem boundary enforcement (PD-98): ADOPTED WITH MODIFICATION

Already built:

- the output directory is created 0700 and checked with `lstat`;
- files are created 0600, with `O_EXCL` for temporary files;
- `ctx.stat` never follows a symlink, and `ctx.list_dir` reports entries without following them (a link planted in a watched folder is recorded as a link);
- every requested path is resolved canonically and checked against the declared reads and denies.

F-1 (Low to Medium, simulated, fix planned).

- **The window.** `ctx.read_text` checks the resolved path and then opens it. If someone who can write into a watched folder swaps a directory for a symlink between the check and the open, the kernel follows it. A deterministic simulation read the contents of a denied subtree through that window (evidence/r4.6/read_race_simulation.txt).
- **What limits it:**
 - it reaches only a denied subtree *inside* a declared read (a "gap" Landlock cannot express, recorded in `DAEMON_START.landlock.gaps`); everything outside the declared reads stays kernel-blocked;
 - under systemd, `InaccessiblePaths=` hides the gap entirely.
- **The fix: check after opening, not only before.** A per-component `O_NOFOLLOW` walk with `dir_fd` would close the window, and the simulation shows it refusing the swapped directory. But the skeleton's audit hook judges relative paths against the working directory, so the walk needs designing with the hook, not bolted on. The planned fix opens the file, then asks the kernel which file it actually opened (the descriptor's path), and re-checks that path against the policy before reading a byte. No semantics change for correct daemons, so no contract major.
- **Device and inode pinning** is needed where a check and a use are separate operations. The post-open check removes that gap for reads. For the output directory, the recorded device and inode at start-up add little, because it is 0700 and owned by the daemon's user; it is optional.

- **0_NOFOLLOW on the ledger and lock opens** is cheap and does not change behaviour. It is added with the F-1 fix.

4. Decisions

ID	Decision	Verdict
PD-93	No disassembly gate. Execute only on system paths (HF-36, built); digest-pinned allowlisted executables in DAEMON_START, compared by the register	REJECTED as proposed; replacement ADOPTED
PD-94	An activation-time battery check of each allowlisted executable (owner, writability, system path, no RPATH/RUNPATH outside system library directories, digest), using the standard library	ADOPTED WITH MODIFICATION
PD-95	Containment of untrusted text: built for the digest. For models, delimiters are a mitigation and authority separation is the guarantee (PD-61)	ADOPTED
PD-96	More always-denied credential stores, and secret-shaped names refused by ctx, in contract 4.0.0, with the stated limits	ADOPTED WITH MODIFICATION
PD-97	In the supervisor/worker split, the supervisor alone holds the ledger; the worker writes only private scratch space	ADOPTED (adds to PD-72)
PD-98	F-1 closed by a check after opening; 0_NOFOLLOW on output-directory opens; inode pinning optional	ADOPTED WITH MODIFICATION

WASI with fuel stays **DEFERRED** under PD-73 and PD-74. Landlock and privilege dropping are **already built**, now including execute-denial.

5. What changes in the code map

Module	Change	When
landlock.py	Execute only on system paths (HF-36)	Built, r4.6
runtime.py	DAEMON_START.tools gains each executable's SHA-256 (PD-93)	Next, additive
battery.py	An executable-provenance check (PD-94)	With DB-21 and DB-22
context.py, guard.py	F-1's check after opening; secret-shaped names refused (PD-96, 4.0.0)	F-1 next; names with 4.0.0
manifest.py	Credential stores join BASE_DENY (PD-96)	Contract 4.0.0
ledger.py, runtime.py	0_NOFOLLOW on the ledger, lock and digest opens (PD-98)	With F-1